



République du Bénin

Université d'Abomey-Calavi



Institut de Formation et de Recherche en Informatique (IFRI)

Cours d'Introduction aux technologies émergentes

Exposé sur la blockchain

Thème :

Exploration des meilleures pratiques et des normes de sécurité pour le développement d'applications basées sur la blockchain

Un travail de :

BLEOSI Cédric

MONTCHO Wesley

SAIDOU Farid

SONON Rivéros

Sous la supervision de :

Professeur

Eugène C. EZIN

Année académique : 2024 – 2025

Plan

Introduction

- I. Les technologies performantes adaptées pour le développement d'applications basées sur la blockchain
- II. Les principales failles et menaces auxquelles sont exposées les applications basées sur la blockchain
- III. Les meilleures pratiques et les normes de sécurité pour le développement d'applications basées sur la blockchain
a- Les meilleures pratiques de développement
b- Les normes de sécurité pour le développement

Conclusion

Introduction

Dans un monde où les applications basées sur la blockchain prennent de plus en plus d'importance, la sécurité est devenue un enjeu incontournable. Bien que la technologie blockchain elle-même soit réputée pour sa robustesse et sa résistance aux falsifications, le développement d'applications sur cette infrastructure reste soumis à des vulnérabilités. Celles-ci peuvent mettre en péril des millions de transactions et la confiance des utilisateurs. Cet exposé vise à explorer les meilleures pratiques et les normes de sécurité qui permettent de protéger les applications décentralisées (dApps) et les contrats intelligents. Nous examinerons les mesures concrètes et les protocoles recommandés pour minimiser les risques, en abordant des aspects tels que la gestion des clés, la vérification des contrats, et la protection contre les attaques courantes. Ce parcours nous montrera comment sécuriser au mieux les applications blockchain pour garantir une utilisation fiable et sécurisée.

I. Les technologies performantes adaptées pour le développement d'applications basées sur la blockchain

Technologie révolutionnaire qui offre une transparence accrue, une sécurité renforcée et une immuabilité des données, la blockchain a pris d'assaut de nombreux secteurs (fiance, santé, logistique...). Certaines technologies sont plus adaptées que d'autres pour le développement d'applications basées sur la blockchain. Voici certaines des plus répandues.

Solidity

Solidity est l'un des langages les plus réputés pour le développement d'applications basées sur la blockchain Ethereum. Il a été initialement conçu pour écrire des contrats intelligents et est fortement pris en charge par la communauté par la communauté Ethereum. Ses points forts sont :

- Solide support de la communauté Ethereum
- Facilité d'utilisation pour les développeurs familiarisés avec JavaScript
- Efficacité pour écrire des contrats intelligents basés sur la blockchain Ethereum.

C++

Connu pour le développement de logiciels, le langage C++ est aussi utilisé dans la conception d'applications basées sur la blockchain. Le Bitcoin qui est la première et la plus célèbre des blockchains est en grande partie codée avec du C++. Ses avantages sont :

- Performance élevée (vitesse d'exécution pour gérer les processus de validation et de consensus)
- Vaste bibliothèque standard
- Parallélisme et multitraitement (pour gérer les validations multiples sur la blockchain).

Go

Go (ou Golang) est un langage de développement développé par Google et qui est utilisé dans de nombreux projets blockchain, notamment Binance. Il est apprécié pour sa simplicité, sa rapidité d'exécution et sa capacité à gérer la concurrence.

II. Les principales failles et menaces auxquelles sont exposées les applications basées sur la blockchain

Même si elles sont réputées pour leur sécurité renforcée, les applications basées sur la blockchain sont exposées à de nombreuses failles et vulnérabilités.

Attaques 51% : Un attaquant contrôlant plus de 50% de la puissance de calcul du réseau peut inverser des transactions et manipuler l'historique de la blockchain.

Attaque Sybil : Elle consiste pour un attaquant à créer un grand nombre d'identités factices (des "sybils") au sein du réseau, afin de prendre le contrôle ou d'influencer les décisions du système.

L'attaque par réentrée

Elle exploite une faiblesse dans la logique d'un contrat pour effectuer des appels récurifs, permettant ainsi à un attaquant de vider le contrat de ses fonds. Cette attaque est possible en raison de la nature asynchrone des transactions sur les blockchains. Entre le moment où un contrat envoie des fonds et le moment où la transaction est définitivement confirmée, il existe une fenêtre d'opportunité pour un attaquant de lancer une attaque par réentrée.

L'attaque par rejeu

Une attaque par rejeu consiste à relancer une transaction en utilisant une signature précédemment utilisée pour voler des fonds. L'une des attaques par rejeu les plus connues de ces dernières années a été le vol de 20 millions de

tokens \$OP au teneur de marché Wintermute sur Optimism, qui était une attaque par jeu inter-chaînes.

L'attaque par déni de service (Dos)

L'attaque par déni de service (DoS) en blockchain consiste à surcharger un réseau ou un contrat intelligent de manière à le rendre indisponible ou à empêcher son bon fonctionnement. En général, une attaque DoS vise à épuiser les ressources d'un contrat ou à exploiter une faille pour bloquer les opérations normales.

III. Les meilleures pratiques et normes de sécurité pour le développement d'applications basées sur la blockchain

Face aux nombreuses failles et vulnérabilités évoquées précédemment, de bonnes pratiques et des normes de sécurité ont été établies pour sécuriser les applications basées sur la blockchain.

a- Les meilleures pratiques

Parmi les meilleures pratiques pour réussir le développement d'applications basées sur la blockchain, on peut évoquer :

- Choisir la bonne plateforme blockchain. Il existe de nombreuses plateformes blockchain disponibles sur le marché, chacune avec ses propres fonctionnalités, avantages et limites. Certains des plus populaires sont Ethereum, Hyperledger Fabric, Corda, Stellar et EOS. En fonction des objectifs, des besoins et des contraintes de votre projet, vous devez sélectionner la plateforme qui correspond le mieux à votre cas d'utilisation et à vos exigences.
- Définir les exigences métier et les cas d'utilisation. Avant de commencer à coder et à créer votre solution blockchain, vous devez d'abord définir les exigences commerciales et les cas d'utilisation que vous souhaitez aborder avec la blockchain. Cela vous aidera à clarifier la portée, les

objectifs et les attentes de votre projet, ainsi qu'à identifier les principales parties prenantes, utilisateurs et bénéficiaires.

- Concevoir les contrats intelligents et les structures de données. Une fois que vous avez défini les exigences commerciales et les cas d'utilisation, vous pouvez commencer à concevoir les contrats intelligents et les structures de données qui mettront en œuvre la logique et les fonctionnalités de votre solution blockchain. Les contrats intelligents sont des programmes auto-exécutables qui s'exécutent sur la blockchain et définissent les règles et conditions des transactions et des interactions.
- Faire auditer le code par des experts en sécurité pour identifier et corriger les vulnérabilités avant le déploiement. Utiliser des outils de test automatisés tels que MythX, Slither, et Oyente pour identifier des failles potentielles. Diviser le code en modules distincts pour faciliter la maintenance et minimiser l'impact des erreurs potentielles et adopter des modèles de conception sécurisés comme checks-effects-interactions pour éviter des problèmes tels que les attaques de reentrancy.

b- Les normes de sécurité

En développement logiciel en général, il existe plusieurs normes de sécurité telles que : ISO/IEC 27001, OWASP, NIST SP 800-53, PCI-DSS, GDPR/RGPD. Ces normes définissent des règles de conduite à respecter pendant le cycle de vie des logiciels / systèmes d'informations. L'avènement des blockchains a conduit à la mise en place de certaines règles spécifiques et à certaines normalisations.

Les normes relatives au développement d'applications blockchain sont entre autres :

- **ISO/TC 307** : Normes spécifiques pour la blockchain, notamment pour la sécurité, l'interopérabilité et la gestion des risques.

- **NIST Blockchain Guidelines** : Directives du NIST pour la sécurité, l'identité, et la confidentialité dans les applications blockchain.
- **Sécurité des Smart Contracts (OpenZeppelin)** : Bibliothèques et bonnes pratiques pour sécuriser les contrats intelligents, en particulier sur Ethereum.
- **Gestion de la cryptographie (algorithmes et clés)** : Utilisation de normes robustes pour le chiffrement (SHA-256, ECC) et la gestion sécurisée des clés privées (HSM, multi-signatures).
- **Test et audit de sécurité (ConsenSys, Trail of Bits)** : Pratiques d'audit spécifiques aux smart contracts pour prévenir les vulnérabilités (réentrance, overflow).

c- Les patterns de résolution

Des développeurs d'applications blockchains ont déjà rencontré certains problèmes plus ou moins récurrents et ont mis en place des "patterns de résolutions". Parmi ces patterns on peut citer :

- Checks-effects-interaction pattern : Lorsqu'un contrat appelle un autre contrat, il lui transmet le contrôle. Le contrat appelé peut alors, à son tour, revenir dans le contrat qui l'a appelé et essayer de manipuler son état ou de détourner le flux de contrôle par le biais d'un code malveillant. Il faut alors suivre un ordre de code fonctionnel recommandé, dans lequel les appels aux contrats externes sont toujours la dernière étape, afin de réduire la surface d'attaque d'un contrat manipulé par ses propres contrats appelés de l'extérieur.
- Emergency stop (circuit breaker) pattern : Étant donné qu'un contrat déployé est exécuté de manière autonome sur le réseau Ethereum, il n'existe aucune option permettant d'interrompre son exécution en cas de bogue majeur ou de problème de sécurité. Il faut alors Incorporer une fonctionnalité d'arrêt d'urgence dans le contrat qui peut être

déclenchée par une partie authentifiée pour désactiver les fonctions sensibles.

- Rate limit pattern : Une demande de précipitation sur une certaine tâche n'est pas souhaitable et peut entraver la bonne exécution opérationnelle d'un contrat. Il faut réguler la fréquence d'exécution d'une tâche au cours d'une période donnée.
- Speed bump pattern : L'exécution simultanée de tâches sensibles par un grand nombre de parties peut faire échouer un contrat. Prolonger l'exécution des tâches sensibles pour prendre des mesures contre les activités frauduleuses.

Conclusion

En conclusion, l'exploration des meilleures pratiques et des normes de sécurité pour le développement d'applications blockchain met en lumière l'importance cruciale de la sécurité dans un écosystème où la confiance est fondée sur la transparence et l'immutabilité des données. Adopter une approche rigoureuse dans la conception, le développement, et la maintenance de ces applications est essentiel pour éviter des failles de sécurité coûteuses et préserver la confiance des utilisateurs.

Les bonnes pratiques, telles que la vérification des contrats intelligents, la gestion rigoureuse des permissions et des identités, et l'application de modèles de sécurité éprouvés, contribuent à protéger les systèmes blockchain contre les attaques et à renforcer leur résilience. Enfin, l'adoption de normes de sécurité internationales et de frameworks de gestion des risques permet d'uniformiser les efforts de sécurité et d'instaurer des bases solides pour les applications de demain. En suivant ces lignes directrices, nous pouvons bâtir un environnement blockchain plus sûr, qui soutient l'innovation tout en protégeant ses utilisateurs.

Bibliographie :

- <https://blockcore.fr/quels-langages-de-programmation-blockchain/>
- <https://talks.freelancerepublik.com/blockchain-quel-langageprogrammation-utiliser/>
- <https://coinexfrench.medium.com/coinex-research-introduction-auxvuln%C3%A9rabilit%C3%A9s-et-attaques-courantes-dans-les-contratse2a329ea80ad>

Référence

Smart Contracts: Security Patterns in the Ethereum Ecosystem and Solidity, Maximilian Wöhrer and Uwe Zdun, University of Vienna, Faculty of Computer Science, Währingerstraße 29, 1090 Vienna, Austria

Lien: <https://eprints.cs.univie.ac.at/5433/7/sanerws18iwbosemain-id1-p-380f58e-35576-preprint.pdf>

Pages 5, 6, 7